Pentesting Fundamentals

A penetration test involves using the same tools, techniques, and methodologies that someone with malicious intent would use and is similar to an audit.

Penetration Testing Ethics

penetration test is an **authorised audit** of a computer system's security and defences as agreed by the owners of the systems. The legality of penetration is pretty clear-cut in this sense; anything that falls outside of this agreement is deemed unauthorised.

a formal discussion occurs between the penetration tester and the system owner. Various tools, techniques, and systems to be tested are agreed on. This discussion **forms the scope of the penetration testing agreement** and will determine the course the penetration test takes.

Hat Category	Description	Example
White Hat	These hackers are considered the "good people". They remain within the law and use their skills to benefit others.	For example, a penetration tester performing an authorised engagement on a company.
Grey Hat	These people use their skills to benefit others often; however, they do not respect/follow the law or ethical standards at all times.	For example, someone taking down a scamming site.
Black Hat	These people are criminals and often seek to damage organisations or gain some form of financial benefit at the cost of others.	For example, ransomware authors infect devices with malicious code and hold data for ransom.

Rules of Engagement (ROE)

The ROE is a document that is created at the initial stages of a penetration testing engagement. This document consists of three main sections, which are ultimately responsible for deciding how the engagement is carried out. The SANS institute has a great example of this document which you can view online here.

Section	Description
Permission	This section of the document gives explicit permission for the engagement to be carried out. This permission is essential to legally protect individuals and organisations for the activities they carry out.
Test Scope	This section of the document will annotate specific targets to which the engagement should apply. For example, the penetration test may only apply to certain servers or applications but not the entire network.
Rules	The rules section will define exactly the techniques that are permitted during the engagement. For example, the rules may specifically state that techniques such as phishing attacks are prohibited, but MITM (Man-in-the-Middle) attacks are okay.

Penetration Testing Methodologies

Penetration tests can have a wide variety of objectives and targets within scope. Because of this, no penetration test is the same, and there are no one-case fits all as to how a penetration tester should approach it.

General structure of methodologies:

Stage	Description
Information Gathering	This stage involves collecting as much publically accessible information about a target/organisation as possible, for example, OSINT and research. **Note:** This does not involve scanning any systems.
Enumeration/Scanning	This stage involves discovering applications and services running on the systems. For example, finding a web server that may be potentially vulnerable.
Exploitation	This stage involves leveraging vulnerabilities discovered on a system or application. This stage can involve the use of public exploits or exploiting application logic.
Privilege Escalation	Once you have successfully exploited a system or application (known as a foothold), this stage is the attempt to expand your access to a system. You can escalate horizontally and vertically, where horizontally is accessing another account of the same permission group (i.e. another user), whereas vertically is that of another permission group (i.e. an administrator).
Post-exploitation	This stage involves a few sub-stages: **1.** What other hosts can be targeted (pivoting) **2.** What additional information can we gather from the host now that we are a privileged user **3.** Covering your tracks **4.** Reporting

OSSTMM

The Open Source Security Testing Methodology Manual provides a detailed framework of testing strategies for systems, software, applications, communications and the human aspect of cybersecurity.

The methodology focuses primarily on how these systems, applications communicate, so it includes a methodology for:

1. Telecommunications (phones, VoIP, etc.)
2. Wired Networks
3. Wireless communications

Advantages	Disadvantages
Covers various testing strategies in-depth.	The framework is difficult to understand, very detailed, and tends to use unique definitions.
Includes testing strategies for specific targets (I.e. telecommunications and networking)	*Intentionally left blank.*
The framework is flexible depending upon the organisation's needs.	*Intentionally left blank.*
The framework is meant to set a standard for systems and applications, meaning that a universal methodology can be used in a penetration testing scenario.	*Intentionally left blank.*

OWASP

The "Open Web Application Security Project" framework is a community-driven and frequently updated framework used solely to test the security of web applications and services.

The foundation regularly writes reports stating the top ten security vulnerabilities a web application may have, the testing approach, and remediation.

Advantages	Disadvantages
Easy to pick up and understand.	It may not be clear what type of vulnerability a web application has (they can often overlap).
Actively maintained and is frequently updated.	OWASP does not make suggestions to any specific software development life cycles.
It covers all stages of an engagement: from testing to reporting and remediation.	The framework doesn't hold any accreditation such as CHECK.
Specialises in web applications and services.	*Intentionally left blank.*

NIST Cybersecurity Framework 1.1

The NIST Cybersecurity Framework is a popular framework used to improve an organisations cybersecurity standards and manage the risk of cyber threats. This framework is a bit of an honourable mention because of its popularity and detail.

The framework provides guidelines on security controls & benchmarks for success for organisations from critical infrastructure (power plants, etc.) all through to commercial.

Advantages	Disadvantages
The NIST Framework is estimated to be used by 50% of American organisations by 2020.	NIST has many iterations of frameworks, so it may be difficult to decide which one applies to your organisation.
The framework is extremely detailed in setting standards to help organisations mitigate the threat posed by cyber threats.	The NIST framework has weak auditing policies, making it difficult to determine how a breach occurred.
The framework is very frequently updated.	The framework does not consider cloud computing, which is quickly becoming increasingly popular for organisations.
NIST provides accreditation for organisations that use this framework.	*Intentionally left blank.*
The NIST framework is designed to be implemented alongside other frameworks.	*Intentionally left blank.*

NCSC CAF

The Cyber Assessment Framework (CAF) is an extensive framework of fourteen principles used to assess the risk of various cyber threats and an organisation's defences against these

The framework applies to organisations considered to perform "vitally important services and activities" such as critical infrastructure, banking, and the likes. The framework mainly focuses on and assesses the following topics:

- Data security
- System security
- Identity and access control
- Resiliency
- Monitoring
- Response and recovery planning

Advantages	Disadvantages
This framework is backed by a government cybersecurity agency.	The framework is still new in the industry, meaning that organisations haven't had much time to make the necessary changes to be suitable for it.
This framework provides accreditation.	The framework is based on principles and ideas and isn't as direct as having rules like some other frameworks.
This framework covers fourteen principles which range from security to response.	Intentionally left blank.

Black box, White box, Grey box Penetration Testing

Black-Box Testing

This testing process is a high-level process where the tester is not given any information about the inner workings of the application or service.

The tester acts as a regular user testing the functionality and interaction of the application or piece of software. This testing can involve interacting with the interface, i.e. buttons, and testing to see whether the intended result is returned. No knowledge of programming or understanding of the programme is necessary for this type of testing.

Grey-Box Testing

This testing process is the most popular for things such as penetration testing. It is a combination of both black-box and white-box testing processes. The tester will have some **limited** knowledge of the internal components of the application or piece of software. Still, it will be interacting with the application as if it were a black-box scenario and then using their knowledge of the application to try and resolve issues as they find them.

With Grey-Box testing, the limited knowledge given saves time, and is often chosen for extremely well-hardened attack surfaces.

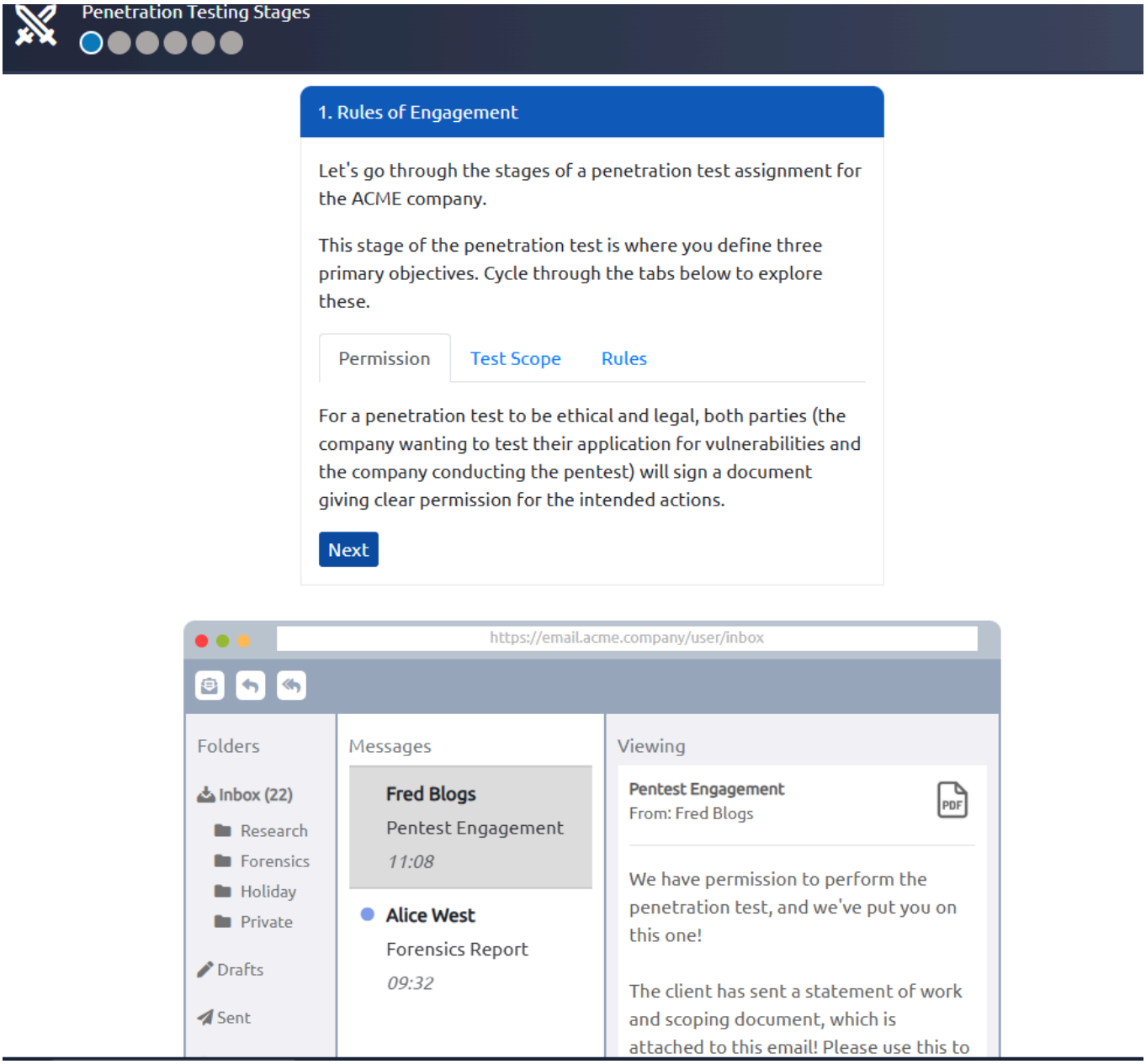
White-Box Testing

This testing process is a low-level process usually done by a software developer who knows programming and application logic. The tester will be testing the internal components of the application or piece of software and, for example, ensuring that specific functions work correctly and within a reasonable amount of time.

The tester will have **full** knowledge of the application and its expected behaviour and is much more time consuming than black-box testing. The full knowledge in a White-Box testing scenario provides a testing approach that guarantees the entire attack surface can be validated.

Practical: ACME Penetration Test

ACME has approached you for an assignment. They want you to carry out the stages of a penetration test on their infrastructure.



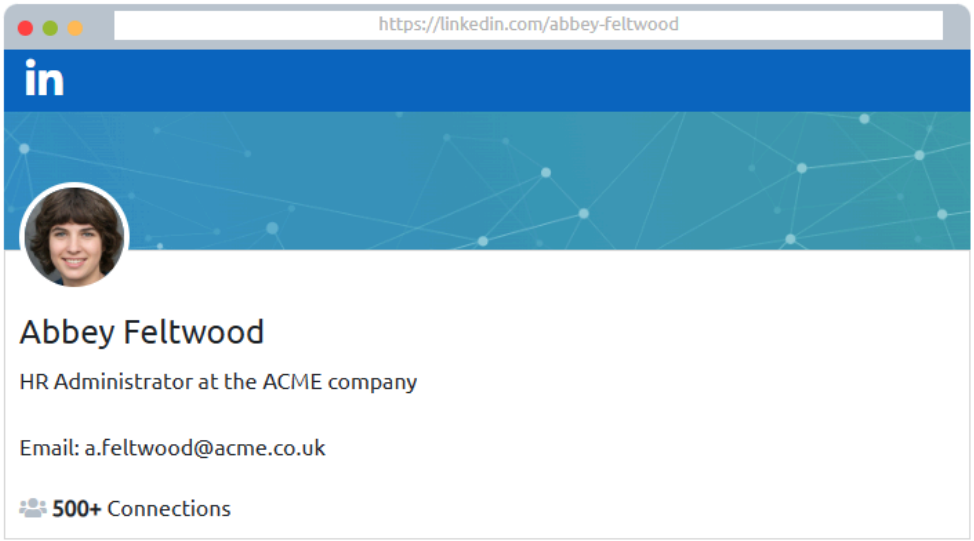
The ROE lays out the rules of the penetration test and is the scope you operate in anything outside of this scope is unauthorised. It explains the permission, test scope and rules

2. Information Gathering

The information gathering stage of an engagement is often undervalued. This stage involves using publicly accessible channels to collect intel on your target.

Abbey, who has a public profile on LinkedIn, advertises that she works for ACME and even includes her email in her bio, which is a possible way we can target her work laptop and thus the company.

Next



information gathering is important as there are many ways to gain different types of information which can help find an attack surface

3. Enumeration & Scanning

The goal of this stage is to get a complete picture of your target. A penetration tester will try to identify user accounts, machines on their network, network shares, applications etc. Information gathered from stage 2, and the engagement scope document will help in enumerating your target.

The enumeration phase is very important as your findings are used to exploit your target's systems (stage 4).

Let's pretend Abbey from stage 2 made a post on LinkedIn sharing a blog post she wrote about ACME. From this post, you find ACME's web server's IP **"96.37.50.151"**; try scanning it.

Next

IP Address | Scan Target

```
user@thm:~$ scan 96.37.50.151

Starting vulnerability scan
Vulnerability scan for 96.37.50.151
Service Vulnerable?
Web Yes
Login No
user@thm:~$ scan
```

Scans help identify open ports that are possibly vulnerable

Penetration Testing Stages

4. Exploitation

The exploitation stage involves the knowledge from your enumeration to now identify and exploit vulnerabilities in any of their applications (that are in scope).

For example, we enumerated ACME's website in stage 3 and found that it was vulnerable. We would now exploit this vulnerability, thus (ethically) hacking ACME's website.

Exploitation is the use of a vulnerability discovered to gain un-authorised access to an information security system or data.

Next

```
msf exploit(handler) > exploit -k -z
[*] Exploit running as background job
[*] Started reverse TCP handler on 127.0.0.1:4444
[*] Starting the payload handler
[*] Sending stage (149882 bytes) to 96.37.50.151
[*] Meterpreter session 1 opened
meterpreter >
```

Attacker

The target machine is being attacked using a tool called Metasploit, something you'll learn about on TryHackMe

Target

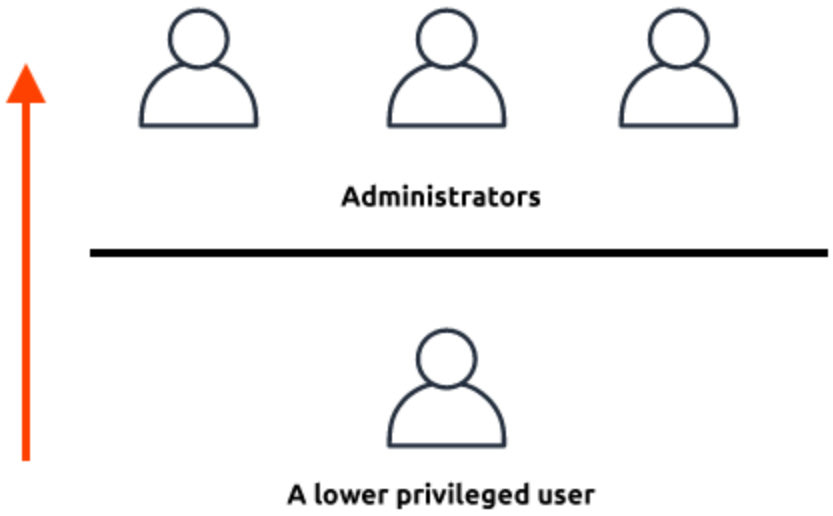
exploiting is where you take advantage of the weakness found in the enumeration and scanning stage

5. Post Exploitation

The post exploitation stage starts when you've gained unauthorised access to a system. At this stage of the engagement, your main goals will be to maintain access to the system and escalate your privileges within the system to a super user or administrator user. Systems are usually set up with normal users that don't have access to various sensitive files and functions - Gaining access to higher privileged users (such as administrators) will allow you to perform actions that you wouldn't be able to as a normal user (such as reading sensitive files and gaining access to all programs within the system).

After doing this, you'll be extracting sensitive information from the system and attacking other components in the environment (e.g. if the system is part of a network, you will attempt to gain access to other machines in the network).

Next



post exploitation is when you have gained access to a system and try to escalate privileges to a higher privileged user which allows to extract more sensitive information as admins have more control of the system.

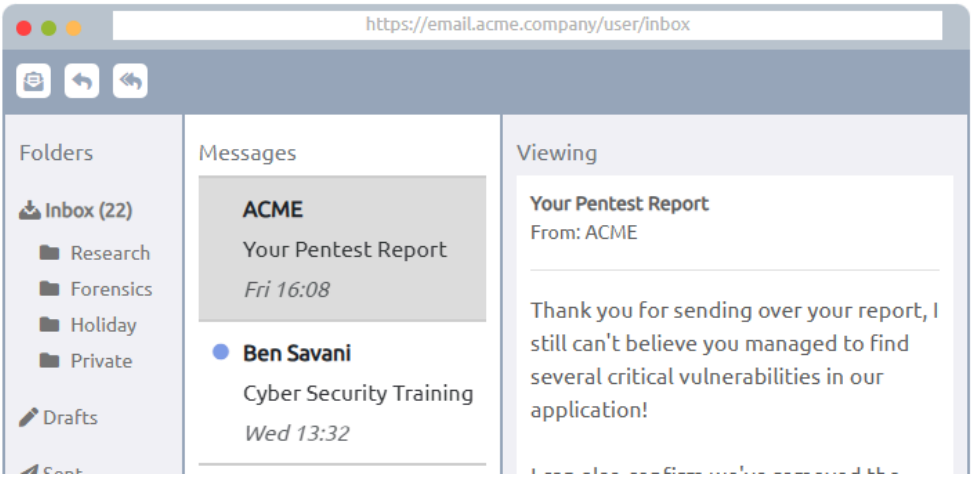
Penetration Testing Stages

6. Pentest Report & Clearing-up

This stage usually occurs at the end of a penetration test. As a penetration tester, you will have to explain the results of your engagement to the client. This is usually done in the form of a report that contains details regarding any security issues you've found and how to mitigate them. The client will use this report to understand the security issues and fix the flaws in the technology stack that was tested.

It's also best practice to clean up the environment you've been testing (where possible). For example, if you were provided access to machines or tooling by the client, you need to delete any artefacts that have been created as a result of testing.

Use **THM{PENTEST_COMPLETE}** to answer the task question on TryHackMe.



Pentest report and clearing up happens at the end of a penetration test. It shows the outcomes of the test in the form of a report detailing the issues and help the client have an understanding on how to secure their network/tech stack